

区块链信息的安全属性

■ 信息安全三要素

1. **机密性(Confidentiality)**: 使信息不泄露给未授权的个人、实体、进程, 或不被其利用的特性。即确保信息只被授权用户使用。常见的机密性保护手段包括: 密码学加密等信息保密技术, 防窃听和防辐射等电子保密技术, 限制、隔离、掩蔽控制等物理保密措施, 认证(Authentication)及授权(Authorization)等访问控制措施。
2. **完整性(Integrity)**: 使信息数据没有遭受以未授权方式所作的更改或破坏的特性。即确保信息只被授权用户修改, 而在使用、存储、传输等过程中都保持一致性。常见的完整性保护手段为密码学中数字签名(DigitalSignature)技术。
3. **可用性(Availability)**: 已授权实体一旦需要就可访问和使用的数据和资源的特性。即确保信息必须在业务需要时可被访问。可用性保护涉及对节点、网络、存储、计算、身份、软件等的保护, 任何对这些对象的攻击和破坏, 都可能损害可用性。

区块链信息的安全属性

■ 三要素的关系



- 完整性是天平的支柱，一旦完整性得不到保障，机密性和可用性就毫无意义。如口令被非法篡改后，口令的机密性也已经被破坏，同时口令也变得不再可用。
- 机密性和可用性分别在天平的两端，两者相互制衡。机密性越强，则可用性相对被削弱；而可用性越强，则机密性也相对被削弱。
- 在实际应用中，需要综合起来权衡考虑，而不能只片面强调部分安全。绝对安全是不存在的，信息安全保护是一个动态平衡的过程，在这个过程中，核心关键点是保护安全规则，而定义安全规则需要在业务需求和安全风险之间权衡。

区块链信息的安全属性

一、机密性

区块链主要采用数据隔离、地址匿名和信息加密方式提升机密性。

■ 1. 数据隔离方式

区块链系统可以采用类似传统数据库分库、分表的方式，将交易信息按照一定规则分散记录在多个子账本中，从而达到两个效果：一方面实现交易扩容，支持更大的交易规模和交易性能要求；另一方面实现数据隔离，不同用户只允许访问部分子账本从而增强了交易隐私性，提高了交易机密性。

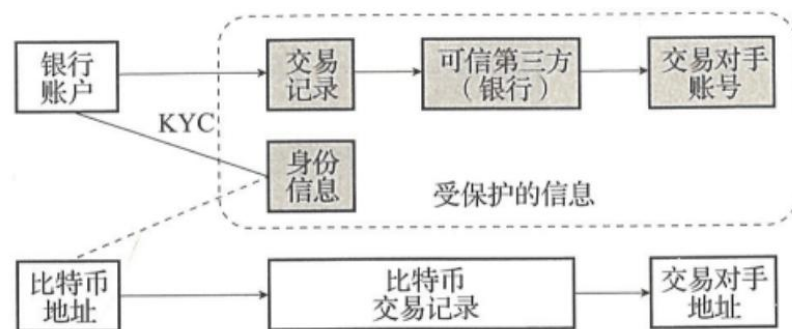
区块链信息的安全属性

■ 2. 地址匿名方式

比特币系统作为首个区块链和加密资产应用，就是采用账户地址匿名化来提高比特币交易双方信息的机密性。比特币系统作为首个区块链和加密资产应用，就是采用账户地址匿名化来提高比特币交易双方信息的机密性。

支持账户地址的“匿名性”

1. 账户地址生成不经过客户身份识别(Know-Your-Customer, KYC)，完全由用户自己产生，是根据椭圆曲线算法产生的公钥，再经过SHA256和RIPEMD-160哈希计算和 Base58 编码等变化的结果。
2. 无法直接通过账户地址，对应到真实身份信息。
3. 一个拥有者的多个账户地址之间无直接联系，其他人无法得知用户实际拥有的比特币数量。



比特币系统的隐私模型

区块链信息的安全属性

公开账本机制在机密保护上的问题

1. 比特币账户地址只是“半匿名”，无法做到完全匿名化

- 用户需要在交易中公开其公钥以便其他节点验证交易有效性，从而暴露了用户地址使用信息
- 交易信息公开，只需知道一个地址就可以找到关联人的一系列地址
- 对区块链数据分析，交易的汇总输入会暴露拥有人的其他地址
- 比特币协议未对通信数据进行加密，协议分析软件能够从比特币交易信息中分析出IP地址与比特币地址的对应关系
- 比特币交易所的实名认证机制，让交易所能够直接将用户信息与地址信息进行关联。

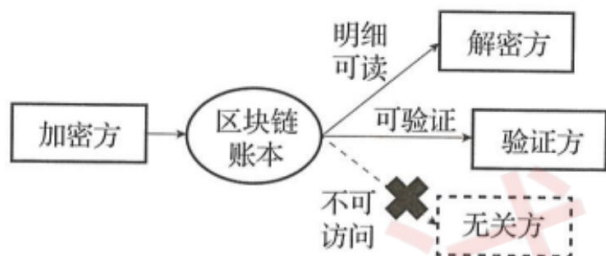
2. 比特币系统没有对交易金额进行机密性保护

- 由于比特币作为公有区块链，需要公开其全部账本，并让所有参与方都能正常读取账本中的历史交易信息，以便对交易正确性进行验证，共同防范“双花”等异常交易。但同时，这也给交易隐私带来了巨大威胁，损害了交易信息的机密性。

通常可采用多个账户地址、混币交易、隐蔽地址和环签名技术来改善其匿名性和机密性不足的问题。

区块链信息的安全属性

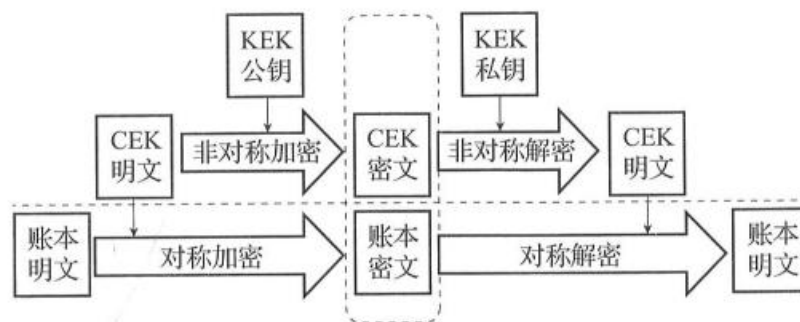
3. 信息加密方式



区块链账本信息的相关方

- 加密方：指当前业务请求方，对提交区块链的交易信息进行加密处理
- 解密方：指其他业务参与方，需读取并解密账本，获得交易详情以便进行相关业务操作
- 验证方：通常是区块链共识节点，需对新产生账本区块中的交易数据进行有效性验证，防止超额消费、双花交易等异常交易。但由于其不参与实际业务流程，其实并不需要了解交易详情。

- 区块链账本信息不仅有“机密性”要求，还有“可验证性”要求
- 对于私有链和联盟链这两种许可型区块链而言，验证节点是相对固定而且是预先知道的，可以使用传统密码学加密方式提高机密性。
- 可以将区块链账本数据、交易数据、配置数据以及账本元数据等，分别进行整体加密或局部加密；前者加密整个账本内容，后者只加密账本中涉及敏感信息的部分内容。此时，可以采用对称加密方式、非对称加密方式加密账本；也可将两者结合起来使用，既保证机密性，又保持较高的加密、解密效率。
- 内容加密密钥(Contents EncryptingKey, CEK)用于加密账本内容
- 密钥加密密钥(KeyEncryptingKey, KEK)则用于加密CEK本身。



区块链信息的安全属性

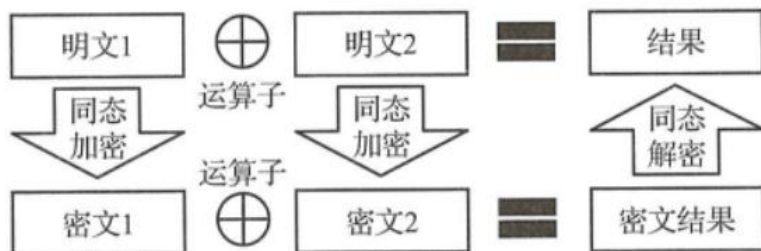
对于公有链这类非许可型区块链而言，由于无法预知谁是验证节点，因此很难简单运用传统加密方式来同时满足机密性和可验证要求。此时，需要引入同态加密或零知识证明等前沿技术。

(1) 同态加密技术

用于解决代数运算中的隐私保护难题。当对密文执行的运算，等价于对明文执行了同样的运算时我们把这种加密方式称为“同态加密”。在区块链和加密资产场景中，可以在保持交易金额机密性的同时，还能让区块链共识节点完成交易的验证，可防止“超额消费或“双花”等异常交易。

(2) 零知识证明

证明者能够使验证者相信某个论断，而无须泄露除了“论断是真实的”之外的任何信息。在区块链和加密资产场景中，可以在保持交易信息机密性的同时，还能让区块链共识节点完成多种交易验证，确保账本的有效性。



区块链信息的安全属性

二、完整性

实现区块链的高度防篡改性，为区块链账本带来完整性保障

数字签名

基于非对称密码学技术实现账本交易信息的防篡改性和不可抵赖性。

空间维度

基于分布式共识机制，能够让不同空间的多个参与主体共同维护账本数据，提高账本的可信度。

时间维度

采用块链结构和时间戳，设计一整套精巧的数据结构来组成账本链条，其中每个区块账本的每一条交易记录都层层受到密码学原理保护。而且随着时间的增长，篡改的难度也成指数级增长

区块链信息的安全属性

三、可用性

在软件系统中，可用性定义为系统功能和工作时间的比例。可用性受到系统错误基础设施恶意攻击和系统负载的影响。它通常以正常运行时间的百分比来衡量，是系统性能的一个指标，确保在合理的时间内响应用户的请求。

区块链系统通过在网络、存储和计算等方面实现极大的冗余部署，从而具有较强的可用性，可提供24x7全天候高可用运行能力。

■ 网络方面

- 区块链系统基于已有网络，实现全球大范围多节点部署运行，在满足共识机制最小组网要求下，即使大部分节点因为各种原因宕机，也不会影响整个网络的运行，从而具有极大的可用性。例如，比特币和以太坊网络，分别由全球分散的上万个左右的节点共同组网，形成一个大型软件定义网络 (SoftwareDefined Net-work; SDN)，哪怕99%节点宕机，只要还有3~5个共识节点能正常工作，其可用性就不受影响。

■ 存储和计算方式

- 每个区块链全节点都独立存储区块链全量账本数据的副本，并能根据副本数据独立完成账本验证，以及智能合约的执行，因而具有很强可用性
- 从性能考虑，区块链由于具有冗余多副本，增加了读取操作的可用性；但由于需要通过共识机制实现多副本的一致性，导致其写入操作的可用性较低，尤其与中心化系统相比差距较大。